

AI Critique (200–300 words)

AI generated broad endpoint coverage quickly, but its first-pass cases tended to trust the endpoint summary instead of the normative SRS. It commonly treated any authenticated token as an admin token, omitted ownership checks, and under-specified terminal-state behavior. It also proposed an FR-19 role-update operation even though the published API exposes only list and delete operations. Several generated cases were therefore marked INCOMPLETE because they lacked seed data, cleanup, exact assertions or a schema oracle. Human review was essential for separating a valid security idea from a request that could not be executed against this SUT. The implementation code also demonstrates why specification-driven testing matters: profile update accepts a client-supplied role, admin routes use authentication middleware without an explicit role check, and the order transition handler contains a terminal-state exception that conflicts with FR-10. These are hypotheses until reproduced through the API; reading code alone is not evidence of an observed defect. The main lesson is to use AI as a coverage assistant, not as an authority. Prompts must force separate passes for partitions, state graphs, authorization, injection, schema and negative paths. Every output needs a human decision, traceability to a requirement, executable data, and an expected result. The final suite should preserve AI mistakes in the audit trail, show the correction, and explain why the omission occurred. This workflow improves both test quality and accountability.